

Phishing Awareness Training

Task 3 – Cyber Security Internship

Topic: Security Audit of a Python Login Application

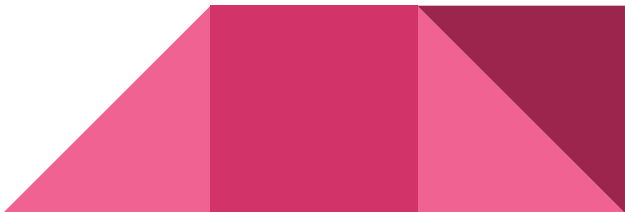
By: Grisha P

Introduction

What is Secure Coding?

Secure coding is the practice of writing software that protects against security vulnerabilities and cyberattacks.

Objectives

- Identify security flaws in code.
 - Prevent unauthorized access.
 - Protect sensitive information.
 - Improve software reliability.
- 

Application Selected

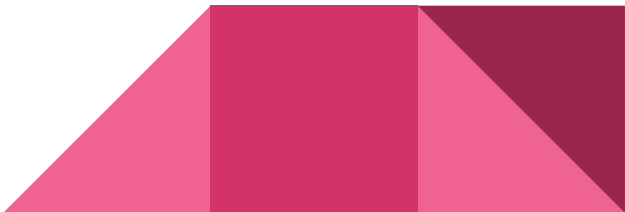
Language: Python

Application: Simple Login System using SQLite

Purpose:

The application allows users to log in by entering a username and password stored in a database.

Review Method:

- Manual code inspection
 - Static analysis using Bandit
- 

Vulnerability 1 – SQL Injection

Vulnerable Code:

```
query = f"SELECT * FROM users WHERE username='{username}' AND  
password='{password}'"
```

Why is it Dangerous?

- User input is directly inserted into the SQL query.
- Attackers can modify the query.
- Authentication can be bypassed.
- Database information may be exposed.

Risk Level:

High



Vulnerability 2 – Plain Text Passwords

Problem

Passwords are compared directly with values stored in the database.

Risks

- Passwords can be stolen if the database is compromised.
- Easy target for attackers.

Recommended Solution

- Store hashed passwords.
- Use secure hashing algorithms such as:
 - bcrypt



Vulnerability 2 – Plain Text Passwords

- Argon2
- PBKDF2



Other Security Issues

Hardcoded Configuration

- Database name is fixed in the program.
- Should be stored in configuration files or environment variables.

Lack of Input Validation

- No validation of username or password.
- May lead to unexpected behavior.

Poor Error Handling

- Database errors are not handled.
 - Sensitive information could be exposed.
- 

Static Code Analysis

Tool Used: Bandit

Bandit is a Python static analysis tool used to identify common security issues.

Installation

```
pip install bandit
```

Run Analysis

```
bandit vulnerable_app.py
```



Static Code Analysis

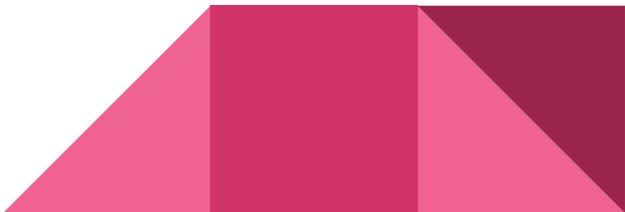
Benefits

- Detects insecure coding patterns
- Easy to use
- Generates security reports



Secure Coding Recommendations

Best Practices

- Use parameterized SQL queries.
 - Hash passwords before storing them.
 - Validate all user input.
 - Avoid hardcoded credentials.
 - Handle exceptions properly.
 - Apply the Principle of Least Privilege.
 - Keep software and libraries updated.
 - Perform regular security testing.
- 

Remediation

Before

SQL query built using string formatting.

After

```
cursor.execute(  
    "SELECT * FROM users WHERE username=? AND password=?",  
    (username, password)  
)
```



Remediation

Improvements

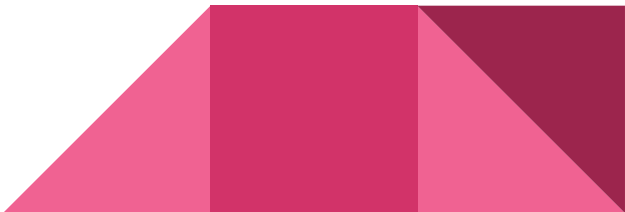
- Prevents SQL Injection.
- More secure database access.
- Better coding practice.
- Easier to maintain.



Conclusion

The security review identified several vulnerabilities in the login application, including SQL injection and insecure password handling.

Key Takeaways

- Never trust user input.
 - Validate and sanitize all inputs.
 - Use parameterized queries.
 - Store passwords securely using hashing.
 - Perform regular code reviews and security testing.
- 

Questions

Phishing Awareness Quiz

Question 1:

What is phishing?

- A programming language
- A cyberattack to steal information
- A web browser
- An antivirus



Phishing Awareness Quiz

Question 1:

What is phishing?

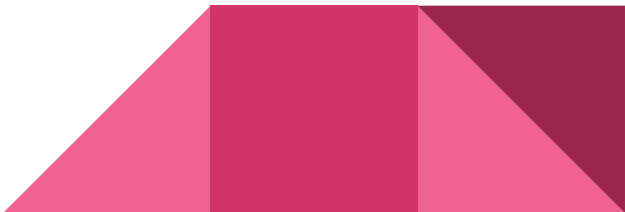
- A programming language
- A cyberattack to steal information 
- A web browser
- An antivirus



Phishing Awareness Quiz

Question 2:

Which is a warning sign of phishing?

- HTTPS
 - Strong password
 - Urgent email asking for credentials
 - Company logo
- 

Phishing Awareness Quiz

Question 2:

Which is a warning sign of phishing?

- HTTPS
- Strong password
- Urgent email asking for credentials 
- Company logo



Phishing Awareness Quiz

Question 3:

What should you do before clicking a link?

- Click immediately
- Verify the URL
- Disable antivirus
- Ignore HTTPS



Phishing Awareness Quiz

Question 3:

What should you do before clicking a link?

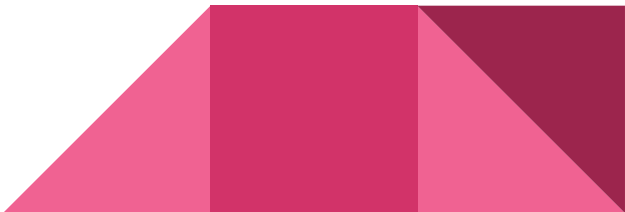
- Click immediately
- Verify the URL 
- Disable antivirus
- Ignore HTTPS



Phishing Awareness Quiz

Question 4:

Which attack uses SMS?

- Smishing
 - Vishing
 - Whaling
 - Spoofing
- 

Phishing Awareness Quiz

Question 4:

Which attack uses SMS?

- Smishing 
- Vishing
- Whaling
- Spoofing



Phishing Awareness Quiz

Question 5:

What is the safest action if you suspect phishing?

- Reply to the sender
- Click the link
- Report the email and delete it
- Share it with friends

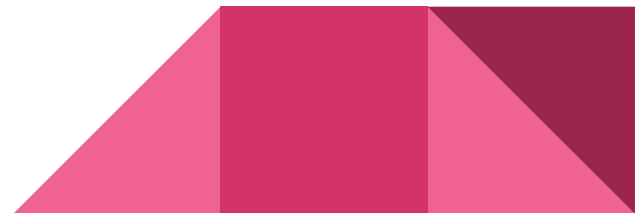


Phishing Awareness Quiz

Question 5:

What is the safest action if you suspect phishing?

- Reply to the sender
- Click the link
- Report the email and delete it 
- Share it with friends





Thank You!